

Proposta de minicurso

Threat Hunting na Prática: da Hipótese à Detecção

1 Dados de identificação

Título. Threat Hunting na Prática: da Hipótese à Detecção, com Estudos de Caso no Hikari.

Autores. Sidnei Barbieri, Ágney Lopes Roth Ferraz e Lourenço Alves Pereira Júnior.

Instituição. Instituto Tecnológico de Aeronáutica (ITA), Divisão de Ciência da Computação.

Apresentador. Sidnei Barbieri, autor da versão atual da plataforma Hikari usada nas práticas.

Natureza. Prático, com três horas de duração, das quais 80 minutos de atividade dos participantes.

2 Dados gerais

2.1 Relevância e atualidade do tema

A detecção automática reconhece o que alguém já viu. O que escapa a ela só é encontrado por quem vai procurar, a partir de uma hipótese sobre como o adversário se comportaria: é isso que se chama caça a ameaças [Sqr16, LB16]. A necessidade está medida. Em quatro anos de alertas de rede de um SOC em operação, analistas receberam de 24 mil a 134 mil alertas por dia, dos quais 0,01% estavam ligados a ataques verdadeiros, com investigações pós-ataque de 53 dias em média [YCW⁺24].

A caça, porém, é pouco ensinada e pouco formalizada. Entrevistas com 22 caçadores experientes mostram que a atividade exige conhecimento tácito e que formular hipóteses é uma dificuldade recorrente [BRPR24]. Entre equipes que caçam para órgãos federais dos Estados Unidos, onde a atividade é obrigatória, a maioria opera sem processo definido [MD24]. A pesquisa automatiza parte da investigação com grafos de proveniência, mas a transferência para a operação ainda esbarra em deficiências práticas, no custo de operação e na qualidade do que o detector entrega ao analista [BJL⁺25, DLJ⁺23, JBEM⁺25], e adversários adaptativos evadem tanto detectores aprendidos quanto regras de SIEM [GHWB23, UHH⁺24]. O tema não costuma estar nas grades de graduação, e o que o curso ensina, formular e refinar uma hipótese sobre telemetria real, é justamente a parte que a automação não substitui.

2.2 Objetivos

O objetivo geral é ensinar o ciclo completo da caça, da hipótese à regra de detecção que ela justifica, com prática sobre telemetria realista. Ao final, o participante deverá ser capaz de:

- (1) situar caça, detecção e resposta nas funções do NIST CSF 2.0 [Nat24, NRSS25];
- (2) escrever uma hipótese testável ancorada numa técnica do MITRE ATT&CK, conhecendo os limites da cobertura como métrica [SAM⁺18, VIR⁺24];
- (3) investigar com KQL e agregações sobre eventos normalizados no Elastic Common Schema [Ela24];
- (4) reconhecer uma isca, a rotina legítima que faz a consulta mais óbvia devolver a resposta errada, e trocar a pergunta;
- (5) converter a caçada numa regra revisável, declarando o falso positivo esperado [Sig24, TMZA25];
- (6) situar a própria prática no estado da arte: onde a pesquisa já automatiza a investigação e onde ainda depende do caçador.

2.3 Tratamento dado ao tema

O curso é prático e segue um laço que se repete em cada um de três estudos de caso: *aprender* o método e o que a pesquisa já sabe, *exercitar* a caçada num caderno Python e *jogar* o mesmo caso na plataforma de caça gamificada Hikari, sob tempo, como numa competição.

Os casos acontecem num cenário próprio, a operadora fictícia Aurora Telecom: 49.277 eventos em seis fontes, ao longo de três dias. Cada caso contém uma isca deliberada, e o diferencial do material está em como ele é conferido. Um gerador determinístico produz os eventos, e um conferidor independente refaz, sobre o conjunto inteiro, o caminho de cada pergunta e o caminho ingênuo de cada isca; se uma mudança no ruído fizer a consulta ingênua acertar, o cenário é reprovado. Nenhum dado de competição real é usado, e o curso pode anteceder uma prova sem entregar respostas.

2.4 Perfil do público e pré-requisitos

Estudantes de graduação e de pós-graduação em Computação e áreas afins, docentes e profissionais de SOC e CSIRT. Não se exige experiência com SIEM: o curso começa pela primeira consulta KQL. Recomenda-se familiaridade com redes e sistemas operacionais e, para os cadernos, noções de Python.

3 Estrutura prevista

A Tabela 1 resume os tópicos, as páginas previstas no capítulo, o tempo de exposição e de prática e a bibliografia de apoio de cada tópico.

Tabela 1: Estrutura prevista. Tempos em minutos; páginas do capítulo.

Tópico	Pág.	Exp.	Prát.	Total	Bibliografia
1. Introdução	2	10	–	10	[Sqr16, YCW ⁺ 24]
2. Conceitos e modelos de caça	4	20	–	20	[B ⁺ 23, Bet18, SAM ⁺ 18, Bia13]
3. O estado da arte	6	20	–	20	[NPD23, BRPR24, BJL ⁺ 25, GHWB23]
4. Ambiente, cenário e plataforma	3	5	10	15	[Ela24, Ken15, DAR20]
5. Caso 1: da força bruta ao privilégio	4	10	25	35	[HDA ⁺ 21, TPY ⁺ 19]
6. Caso 2: o canal que respira	4	10	25	35	[HJS ⁺ 16, SUBG22]
7. Caso 3: do mapa do diretório ao impacto	4	10	20	30	[OALU22, vSWW ⁺ 25]
8. Da caçada à detecção, limites e tendências	3	15	–	15	[UHH ⁺ 24, VIR ⁺ 24, HAL26]
Apêndice: roteiro das 20 perguntas	4	–	–	–	
Referências	8	–	–	–	
Total	42	100	80	180	

4 Detalhamento do conteúdo

1. Introdução (2 páginas). Por que a detecção não basta e o que a caça acrescenta. O laço do curso e o fio condutor que atravessa os três casos: a isca.

2. Conceitos e modelos de caça (4 páginas). Detecção, resposta e caça nas funções do NIST CSF 2.0. Maturidade de caça e os modelos de processo PEAK e TaHiTI. A cadeia de intrusão e o modelo diamante. O ATT&CK e a Pirâmide da Dor, com as ressalvas medidas sobre a cobertura como métrica. Telemetria no ECS, consultas KQL, agregações e pivôs.

3. O estado da arte (6 páginas). O que a pesquisa empírica mediu sobre a operação de SOCs e sobre quem caça. A linha que automatiza a investigação com grafos de proveniência, do resumo de grafos à atribuição, e as razões medidas pelas quais ela ainda não chegou à operação. Inteligência de ameaças estruturada como fonte de hipóteses. Evasão de detectores e de regras. Engenharia de detecção e a qualidade das regras. Cyber ranges e competições como formação de defensores.

4. Ambiente, cenário e plataforma (3 páginas). Por que um cenário próprio, e não uma base pública. A Aurora Telecom, suas fontes e o ruído escolhido para enganar. Como o gabarito e as iscas são conferidos por código. Preparação do ambiente: o caderno roda no navegador e o Hikari fica disponível na nuvem.

5 a 7. Estudos de caso (4 páginas cada). Cada caso tem hipótese, fontes de dados, a consulta ingênua e a isca, a pergunta que resolve, a linha do tempo reconstruída, a regra de detecção derivada com o falso positivo esperado, exercícios e o que a literatura acrescenta sobre aquela técnica.

8. Da caçada à detecção, limites e tendências (3 páginas). O que os três casos têm em comum. Métricas de uma equipe de caça e o que cada uma distorce quando vira meta. Como conduzir um exercício de caça, antes, durante e depois. Limites do material sintético. Modelos de linguagem na resposta a incidentes e o adversário adaptativo.

5 Atividades práticas

Cada prática segue a mesma ordem: primeiro o caderno, que refaz os passos em **pandas** e confere a resposta na última célula; depois o Hikari, onde o participante investiga no SIEM e submete a resposta sob tempo.

- **Prática 1, a origem que entrou** (25 min: 10 no caderno, 15 no Hikari). Individual. A discussão expõe a isca, a sonda de monitoramento com senha vencida, e a troca de pergunta que resolve o caso.
- **Prática 2, o canal que respira** (25 min: 10 e 15). Em duplas: uma pessoa persegue o domínio do canal de comando, a outra o volume que sai, e as duas linhas se encontram na mesma estação.
- **Prática 3, do mapa do diretório ao impacto** (20 min: 5 e 15). Cronometrada como um incidente: parte dos arquivos cifrados, reconstrói o que veio antes e termina com a regra que teria dado tempo de agir.

6 Recursos, material e contingência

Sala com projetor e acesso à internet; cada participante usa o próprio computador, só com navegador. Os cadernos abrem no Google Colab e baixam a evidência sozinhos; a instância do Hikari com o cenário é disponibilizada pelos proponentes. Todo o material é público em <https://hikari-edu.github.io/minicurso/>: capítulo, slides, cadernos, evidência, gerador com conferidor e pacote de desafios. Se a rede da sala falhar, os cadernos rodam localmente com Python e **pandas**, e o Hikari pode ser iniciado localmente com Docker Compose a partir do mesmo pacote.

7 Experiência dos proponentes com o tema

A plataforma Hikari foi descrita no SBSeg 2025 [BBC⁺25] e é usada em competições de caça a ameaças do setor brasileiro de telecomunicações, entre elas o RESEG, promovido pela Agência Nacional de Telecomunicações. A versão atual, desenvolvida pelo apresentador, registra as submissões e as consultas ao SIEM de cada participante, o que permitiu medir, nessas competições, onde os desafios erram e onde os participantes investigam. Os autores também pesquisam inteligência de ameaças estruturada para emulação de adversários e agentes de defesa autônomos.

Referências

- [B⁺23] David Bianco et al. The PEAK threat hunting framework. White paper, Splunk Inc., 2023.
- [BBC⁺25] Sidnei Barbieri, Bruno Moreira Camargos Belo, Leonardo Chahud, Leonardo Vaz de Meneses, Cesar Marcondes, and Lourenço Alves Pereira Júnior. HIKARI — desafios reais, ameaças ocultas: Uma plataforma de threat hunting gamificado. In *Anais do Simpósio Brasileiro de Cibersegurança (SBSeg)*. Sociedade Brasileira de Computação, 2025.
- [Bet18] Betaalvereniging Nederland. TaHiTI: Targeted hunting integrating threat intelligence. Technical report, Betaalvereniging Nederland, 2018.
- [Bia13] David J. Bianco. The pyramid of pain. Enterprise Detection & Response (blog), 2013.
- [BJL⁺25] Tristan Bilot, Baoxiang Jiang, Zefeng Li, Nour El Madhoun, Khaldoun Al Agha, Anis Zouaoui, and Thomas Pasquier. Sometimes simpler is better: A comprehensive analysis of state-of-the-art provenance-based intrusion detection systems. In *34th USENIX Security Symposium*, pages 7193–7212. USENIX Association, 2025.
- [BRPR24] Priyanka Badva, Kopo M. Ramokapane, Eleonora Pantano, and Awais Rashid. Unveiling the hunter-gatherers: Exploring threat hunting practices and challenges in cyber defense. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [DAR20] DARPA. Transparent computing engagement data releases, 2020.
- [DLJ⁺23] Feng Dong, Shaofei Li, Peng Jiang, Ding Li, Haoyu Wang, Liangyi Huang, Xusheng Xiao, Jiedong Chen, Xiapu Luo, Yao Guo, and Xiangqun Chen. Are we there yet? An industrial viewpoint on provenance-based endpoint detection and response tools. In *ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 2396–2410. ACM, 2023.
- [Ela24] Elastic. Elastic common schema (ECS) reference. Documentação oficial, 2024.
- [GHWB23] Akul Goyal, Xueyuan Han, Gang Wang, and Adam Bates. Sometimes, you aren’t what you do: Mimicry attacks against provenance graph host intrusion detection systems. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2023.
- [HAL26] Kim Hammar, Tansu Alpcan, and Emil C. Lupu. Incident response planning using a lightweight large language model with reduced hallucination. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2026.
- [HDA⁺21] Grant Ho, Mayank Dhiman, Devdatta Akhawe, Vern Paxson, Stefan Savage, Geoffrey M. Voelker, and David A. Wagner. Hopper: Modeling and detecting lateral movement. In *30th USENIX Security Symposium*. USENIX Association, 2021.
- [HJS⁺16] Xin Hu, Jiyong Jang, Marc Ph. Stoecklin, Ting Wang, Douglas L. Schales, Dhilung Kirat, and Josyula R. Rao. BAYWATCH: Robust beaconing detection to identify infected hosts in large-scale enterprise networks. In *46th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, pages 479–490, 2016.
- [JBEM⁺25] Baoxiang Jiang, Tristan Bilot, Nour El Madhoun, Khaldoun Al Agha, Anis Zouaoui, Shahrear Iqbal, Xueyuan Han, and Thomas Pasquier. Orthrus: Achieving high quality of attribution in provenance-based intrusion detection systems. In *34th USENIX Security Symposium*. USENIX Association, 2025.
- [Ken15] Alexander D. Kent. Comprehensive, multi-source cyber-security events. Los Alamos National Laboratory, 2015.
- [LB16] Robert M. Lee and David Bianco. Generating hypotheses for successful threat hunting. White paper, SANS Institute, 2016.
- [MD24] William P. Maxam, III and James C. Davis. An interview study on third-party cyber threat hunting processes in the U.S. department of homeland security. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [Nat24] National Institute of Standards and Technology. The NIST cybersecurity framework (CSF) 2.0. Technical Report CSWP 29, NIST, 2024.
- [NPD23] Boubakr Nour, Makan Pourzandi, and Mourad Debbabi. A survey on threat hunting in enterprise networks. *IEEE Communications Surveys & Tutorials*, 25(4):2299–2324, 2023.

- [NRSS25] Alex Nelson, Sanjay Rekhi, Murugiah Souppaya, and Karen Scarfone. Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile. Technical Report NIST SP 800-61r3, National Institute of Standards and Technology, 2025.
- [OALU22] Harun Oz, Ahmet Aris, Albert Levi, and A. Selcuk Uluagac. A survey on ransomware: Evolution, taxonomy, and defense solutions. *ACM Computing Surveys*, 54(11s):238:1–238:37, 2022.
- [SAM⁺18] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. MITRE ATT&CK: Design and philosophy. Technical Report MTR180312, The MITRE Corporation, McLean, VA, 2018.
- [Sig24] SigmaHQ. Sigma: Generic signature format for SIEM systems. Repositório de código aberto, 2024.
- [Sqr16] Sqrrl Data. A framework for cyber threat hunting. White paper, Sqrrl Data, Inc., 2016.
- [SUBG22] Bushra Sabir, Faheem Ullah, Muhammad Ali Babar, and Raj Gaire. Machine learning for detecting data exfiltration: A review. *ACM Computing Surveys*, 54(3):50:1–50:47, 2022.
- [TMZA25] Koen T. W. Teuwen, Tom Mulders, Emmanuele Zambon, and Luca Allodi. Ruling the unruly: Designing effective, low-noise network intrusion detection rules for security operations centers. In *ACM Asia Conference on Computer and Communications Security (AsiaCCS)*, pages 1428–1441. ACM, 2025.
- [TPY⁺19] Kurt Thomas, Jennifer Pullman, Kevin Yeo, Ananth Raghunathan, Patrick Gage Kelley, Luca Invernizzi, Borbala Benko, Tadek Pietraszek, Sarvar Patel, Dan Boneh, and Elie Bursztein. Protecting accounts from credential stuffing with password breach alerting. In *28th USENIX Security Symposium*. USENIX Association, 2019.
- [UHH⁺24] Rafael Uetz, Marco Herzog, Louis Hackländer, Simon Schwarz, and Martin Henze. You cannot escape me: Detecting evasions of SIEM rules in enterprise networks. In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [VIR⁺24] Apurva Virkud, Muhammad Adil Inam, Andy Riddle, Jason Liu, Gang Wang, and Adam Bates. How does endpoint detection use the MITRE ATT&CK framework? In *33rd USENIX Security Symposium*. USENIX Association, 2024.
- [vSWW⁺25] Christian van Sloun, Vincent Woeste, Konrad Wolsing, Jan Pennekamp, and Klaus Wehrle. Detecting ransomware despite I/O overhead: A practical multi-staged approach. In *Network and Distributed System Security Symposium (NDSS)*. The Internet Society, 2025.
- [YCW⁺24] Limin Yang, Zhi Chen, Chenkai Wang, Zhenning Zhang, Sushruth Booma, Phuong Cao, Constantin Adam, Alexander Withers, Zbigniew Kalbarczyk, Ravishankar K. Iyer, and Gang Wang. True attacks, attack attempts, or benign triggers? An empirical measurement of network alerts in a security operations center. In *33rd USENIX Security Symposium*. USENIX Association, 2024.

Currículos resumidos

Sidnei Barbieri (apresentador)

Doutorando no Instituto Tecnológico de Aeronáutica (ITA), onde desenvolve pesquisa em caça a ameaças e em exercícios cibernéticos como instrumentos de medida. Desenvolveu a versão atual da plataforma Hikari e é responsável por ela, inclusive na operação de competições do setor de telecomunicações. Primeiro autor do artigo que apresenta a plataforma no SBSeg 2025 e dos preprints *AutoSUT: The Environment Semantics Gap in Structured CTI for Adversary Emulation* (arXiv 2606.08700, 2026) e *PocketAgents: A Manifest-Driven Library of Autonomous Defense Agents* (arXiv 2605.21694, 2026). Contato: sidneibarbieri@gmail.com.

Ágney Lopes Roth Ferraz

Pesquisador no Instituto Tecnológico de Aeronáutica (ITA). Trabalha com inteligência de ameaças estruturada para emulação de adversários e com agentes de defesa autônomos, e é coautor dos preprints AutoSUT (arXiv 2606.08700, 2026) e PocketAgents (arXiv 2605.21694, 2026).

Lourenço Alves Pereira Júnior

Professor da Divisão de Ciência da Computação do Instituto Tecnológico de Aeronáutica (ITA). Doutor (2016) e mestre (2010) em Ciências de Computação e Matemática Computacional pela Universidade de São Paulo, e bacharel em Ciência da Computação pela Universidade de Alfenas (2006). Pesquisa segurança cibernética, redes de computadores e sistemas operacionais. Coautor do artigo que apresenta a plataforma Hikari no SBSeg 2025 e dos preprints AutoSUT e PocketAgents.